

SIMATS ENGINEERING
ASSESSMENT TOOL I – INDUSTRY PROBLEM TASK

Course:	Code:	CO: CO5
Duration:	Total Marks: 100	Reg No / Name:

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: *Answer all questions. Each question carries 20 marks.*

Code of Conduct:

I M Kavya 192472370 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: *kavya*

QUESTION 1: Windows Domain Network – NULL Sessions, RPC and Weak Shares

1. A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement attacks. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt.

Question:

Analyze the extent of the attack by calculating the number of systems compromised during the initial stage of exploitation. Further, estimate the spread of the attack in the second stage due to lateral movement. Based on your analysis, evaluate whether the network is at risk of a large-scale compromise (greater than 70% of total systems), and justify which vulnerability (NULL sessions, RPC exposure, or weak shares) should be prioritized for immediate mitigation.

Problem Analysis

The organization has 150 interconnected Windows systems. Attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders. The objective is to determine the number of systems compromised during the initial stage, estimate the spread through lateral movement, and evaluate whether the network is at risk of a large-scale compromise.

Given Data

- Total systems = 150
- Systems allowing anonymous enumeration = 45%
- Systems susceptible to SMB-based lateral movement = 60% of anonymous systems

- Each compromised system attempts to access 3 additional systems
- Success probability per attempt = 0.3
- Large-scale compromise threshold = 70%

Step 1: Initial Stage of Exploitation

Number of systems allowing anonymous enumeration:

$$150 \times 0.45 = 67.5$$

Approximately 68 systems allow anonymous enumeration.

Number of systems susceptible to SMB-based lateral movement:

$$67.5 \times 0.60 = 40.5$$

Therefore, the expected initial compromised/susceptible systems are approximately:

40.5 $\approx$ 41 systems

Step 2: Second-Stage Lateral Movement

Each compromised system attempts to access 3 additional systems:

$$40.5 \times 3 = 121.5$$

Expected successful lateral-movement attempts:

$$121.5 \times 0.3 = 36.45$$

Therefore:

36.45 $\approx$ 36 additional systems

Step 3: Total Expected Compromise

Total expected compromised systems:

$$40.5 + 36.45 = 76.95$$

Approximately:

77 systems

Percentage of the network:

$$(76.95 / 150) \times 100 = 51.3\%$$

Therefore:

51.3% of the network could potentially be compromised.

Since:

$$51.3\% < 70\%$$

the network does not cross the specified 70% large-scale compromise threshold.

However, compromising more than half of the network still represents a serious security risk.

Kali Linux Commands

Scan SMB and RPC Services

`nmap -sV -p 135,139,445 <TARGET-IP>`

```
(kavya@kavya)~[~]
$ nmap -sV -p 135,139,445 10.0.2.15
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-25 11:04 +0530
Nmap scan report for 10.0.2.15
Host is up.

PORT      STATE      SERVICE      VERSION
135/tcp    filtered  msrpc
139/tcp    filtered  netbios-ssn
445/tcp    filtered  microsoft-ds

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.99 seconds
```

Check SMB Security Configuration

`nmap --script smb-protocols,smb-security-mode -p 445 <TARGET-IP>`

```
(kavya@kavya)~[~]
$ nmap --script smb-protocols,smb-security-mode -p 445 10.0.2.15
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-25 11:05 +0530
Nmap scan report for 10.0.2.15
Host is up.

PORT      STATE      SERVICE
445/tcp    filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 4.19 seconds
```

Check Anonymous SMB Shares

`smbclient -L //<TARGET-IP>/ -N`

RPC Enumeration

`rpcclient -U "" -N <TARGET-IP>`

Security Analysis

NULL sessions can provide attackers with information about users, shares, groups, and other network resources. RPC exposure can provide additional attack surfaces, while weak SMB shares can facilitate unauthorized access and lateral movement.

The calculations show that although the 70% threshold is not crossed, approximately 51.3% of the network could potentially be affected under the given assumptions.

Recommended Mitigation

1. Disable or restrict NULL sessions and anonymous enumeration.
2. Restrict unnecessary RPC services.
3. Secure SMB shares using proper authentication and authorization.
4. Apply network segmentation.
5. Apply least-privilege access.
6. Monitor lateral movement and abnormal SMB activity.

Final Conclusion

The expected attack spread is approximately 77 systems or 51.3% of the network. The network is not mathematically above the 70% large-scale compromise threshold, but the risk is still significant. NULL-session and anonymous enumeration should receive immediate attention, followed by SMB-share and RPC hardening.

QUESTION 2: RPC Exposure and Exploitation

2. An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Question:

Determine the expected number of systems that can be successfully compromised by an attacker. Additionally, compute the expected number of detection alerts generated during the exploitation process. Based on your results, critically evaluate whether an attacker aiming to remain stealthy would proceed with exploitation or adopt alternative attack strategies, providing justification for your reasoning.

Problem Analysis

The enterprise network consists of 120 systems, of which 70 expose RPC services. The objective is to determine the expected number of systems that can be successfully compromised and the expected number of detection alerts.

Given Data

- Total systems = 120
- RPC-exposed systems = 70
- Vulnerable RPC systems = 40%
- Exploitation success probability = 0.5
- Detection probability = 0.25

Step 1: Number of Vulnerable Systems

Number of vulnerable RPC systems:

$$70 \times 0.40 = 28$$

Therefore:

28 vulnerable systems

Step 2: Expected Successful Compromises

Expected successful compromises:

$$28 \times 0.5 = 14$$

Therefore:

14 systems can be expected to be successfully compromised.

Step 3: Expected Detection Alerts

Expected detection alerts:

$$28 \times 0.25 = 7$$

Therefore:

7 detection alerts are expected.

Step 4: Percentage of Entire Network Compromised

Percentage of the complete network:

$$(14 / 120) \times 100 = 11.67\%$$

Therefore:

Approximately 11.67% of the entire network could be successfully compromised.

Kali Linux Commands

Identify RPC Services

`nmap -sV -p 135,139,445 <TARGET-IP>`

RPC Information Enumeration

`nmap --script rpcinfo -p 135 <TARGET-IP>`

```
(kavya@kavya)~$ nmap -sV -p 135,139,445 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-25 11:31 +0530
Nmap scan report for 192.168.56.101
Host is up (0.00036s latency).

PORT      STATE      SERVICE      VERSION
135/tcp    filtered  msrpc
139/tcp    filtered  netbios-ssn
445/tcp    filtered  microsoft-ds

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 3.68 seconds

(kavya@kavya)~$ nmap --script rpcinfo -p 135 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-25 11:32 +0530
Nmap scan report for 192.168.56.101
Host is up (0.00085s latency).

PORT      STATE      SERVICE
135/tcp    filtered  msrpc

Nmap done: 1 IP address (1 host up) scanned in 2.40 seconds
```

SMB/RPC Security Assessment

`nmap --script smb-security-mode,smb-protocols -p 445 <TARGET-IP>`

Security Analysis

There are 28 potentially vulnerable systems, and the expected successful compromise is 14 systems. Approximately 7 detection alerts are also expected.

For an attacker attempting to remain stealthy, repeated exploitation attempts may increase the probability of detection. Therefore, the attacker may prefer less noisy attack paths depending on the environment.

From the defender's perspective, the expected alerts demonstrate that IDS monitoring can provide useful visibility. However, monitoring should be combined with patch management, firewall restrictions, and network segmentation.

Recommended Mitigation

1. Restrict RPC exposure to systems that require it.

2. Apply security patches.
3. Use firewall rules to restrict RPC access.
4. Monitor abnormal RPC activity.
5. Strengthen IDS/IPS detection.
6. Segment critical systems.

Final Conclusion

The expected number of successful compromises is 14 systems, while approximately 7 detection alerts may be generated. An attacker seeking to remain stealthy would face a meaningful detection risk from repeated exploitation. Therefore, RPC exposure should be minimized, properly secured, and continuously monitored.

QUESTION 3: Cloud Linux Server – Vulnerable Services and Weak Permissions

3. A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Question:

Evaluate the probability that at least one service is vulnerable and can be exploited by an attacker. Further, compute the overall probability of a full system compromise, considering both service exploitation and privilege escalation through weak permissions. Based on your findings, analyze whether strengthening file permissions alone would significantly reduce the overall risk, and justify your conclusion.

Problem Analysis

The Linux server has four internet-facing services. Each service has an independent probability of being vulnerable. The system also has weak file permissions that may enable privilege escalation after initial access.

Given Data

- Service 1 vulnerability probability = 0.30
- Service 2 vulnerability probability = 0.20
- Service 3 vulnerability probability = 0.25
- Service 4 vulnerability probability = 0.15
- Probability of privilege escalation through weak permissions = 0.50

Step 1: Probability That No Service Is Vulnerable

Because the services are independent:

$$P(\text{None}) = (1 - 0.30)(1 - 0.20)(1 - 0.25)(1 - 0.15)$$

$$P(\text{None}) = 0.70 \times 0.80 \times 0.75 \times 0.85$$

$$P(\text{None}) = 0.357$$

Step 2: Probability That at Least One Service Is Vulnerable

$$P(\text{At least one}) = 1 - P(\text{None})$$

$$P(\text{At least one}) = 1 - 0.357$$

$$P(\text{At least one}) = 0.643$$

Therefore:

$$P(\text{At least one}) = 64.3\%$$

There is a **64.3% probability that at least one service is vulnerable.**

Step 3: Probability of Full System Compromise

Assuming that service exploitation provides initial access and weak permissions can subsequently be exploited for privilege escalation:

$$P(\text{Full Compromise}) = P(\text{Initial Access}) \times P(\text{Privilege Escalation})$$

$$P(\text{Full Compromise}) = 0.643 \times 0.50$$

$$P(\text{Full Compromise}) = 0.3215$$

Therefore:

$$P(\text{Full Compromise}) = 32.15\%$$

Kali Linux Commands

Identify Exposed Services

```
nmap -sV -sC <TARGET-IP>
```

Scan Common Service Ports

```
nmap -sV -p 22,80,443,8080 <TARGET-IP>
```

Check for Known Vulnerabilities in an Authorized Lab

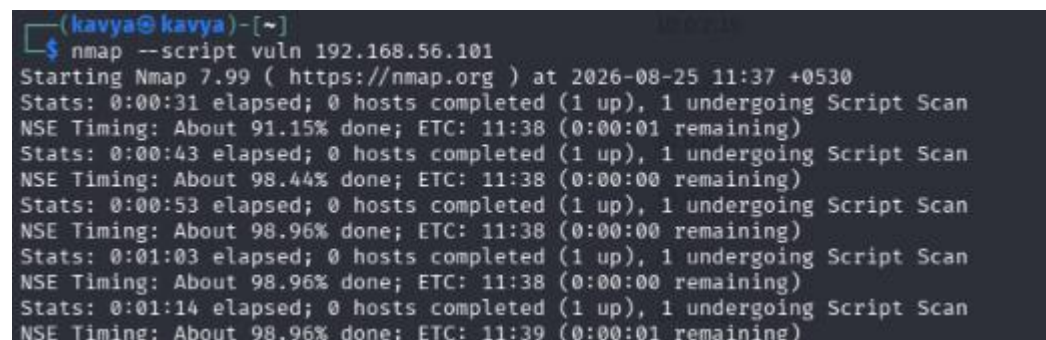
```
nmap --script vuln <TARGET-IP>
```

Inspect File Permissions on an Authorized Linux System

```
ls -la
```

Check SUID Files

```
find / -perm -4000 -type f 2>/dev/null
```



```
(kavya@kavya)-[~]
$ nmap --script vuln 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-25 11:37 +0530
Stats: 0:00:31 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 91.15% done; ETC: 11:38 (0:00:01 remaining)
Stats: 0:00:43 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.44% done; ETC: 11:38 (0:00:00 remaining)
Stats: 0:00:53 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.96% done; ETC: 11:38 (0:00:00 remaining)
Stats: 0:01:03 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.96% done; ETC: 11:38 (0:00:00 remaining)
Stats: 0:01:14 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.96% done; ETC: 11:39 (0:00:01 remaining)
```

Security Analysis

The probability of at least one vulnerable service is 64.3%, indicating that the internet-facing attack surface is significant.

Weak file permissions provide another opportunity after initial access. Although correcting file permissions reduces the probability of full compromise, it does not remove the possibility of

initial access through vulnerable services.

Recommended Mitigation

1. Patch exposed services.
2. Remove unnecessary internet-facing services.
3. Apply least-privilege permissions.
4. Review SUID binaries.
5. Implement network segmentation.
6. Monitor authentication and service activity.

Final Conclusion

The probability of at least one vulnerable service is **64.3%**, while the modeled probability of full compromise is **32.15%**. Strengthening file permissions is important, but it should not be the only mitigation. Vulnerable internet-facing services must also be patched and hardened.

QUESTION 4: NFS Security

4. An organization uses Network File System (NFS) to share resources across three internal subnets. Due to improper configuration, unauthorized access probabilities from these subnets are estimated as 0.4, 0.3, and 0.2, respectively. Once access to the NFS share is obtained, the probability of privilege escalation to root access is 0.7.

Question:

Calculate the probability that at least one subnet successfully gains unauthorized access to the NFS share. Subsequently, determine the overall probability of a complete system compromise. Based on your analysis, evaluate the effectiveness of restricting NFS access to a single subnet as a mitigation strategy, and justify your recommendation.

Problem Analysis

The organization uses Network File System (NFS) across three internal subnets. Each subnet has a probability of unauthorized access. Once access is obtained, there is a 70% probability of privilege escalation to root access.

Given Data

- Subnet 1 unauthorized access probability = 0.4
- Subnet 2 unauthorized access probability = 0.3
- Subnet 3 unauthorized access probability = 0.2
- Probability of privilege escalation = 0.7

Step 1: Probability That No Subnet Gains Unauthorized Access

$$P(\text{None}) = (1 - 0.4)(1 - 0.3)(1 - 0.2)$$

$$P(\text{None}) = 0.6 \times 0.7 \times 0.8$$

$$P(\text{None}) = 0.336$$

Step 2: Probability That at Least One Subnet Gains Unauthorized Access

$$P(\text{Access}) = 1 - P(\text{None})$$

$$P(\text{Access}) = 1 - 0.336$$

$$P(\text{Access}) = 0.664$$

Therefore:

$$P(\text{Access}) = 66.4\%$$

Step 3: Probability of Complete System Compromise

$$P(\text{Complete Compromise}) = P(\text{Access}) \times P(\text{Privilege Escalation})$$

$$P(\text{Complete Compromise}) = 0.664 \times 0.7$$

$$P(\text{Complete Compromise}) = 0.4648$$

Therefore:

$$P(\text{Complete Compromise}) = 46.48\%$$

Step 4: Effect of Restricting NFS to One Subnet

If NFS access is restricted to only Subnet 1:

$$P(\text{Access}) = 0.4$$

Probability of complete compromise:

$$P(\text{Complete Compromise}) = 0.4 \times 0.7$$

$$P(\text{Complete Compromise}) = 0.28$$

Therefore:

$$\text{Complete compromise probability} = 28\%$$

Risk reduction:

$$46.48\% - 28\% = 18.48 \text{ percentage points}$$

Thus, restricting NFS access to one subnet reduces the modeled complete-compromise probability from **46.48% to 28%**.

Kali Linux Commands

Check NFS Ports

```
nmap -p 111,2049 <TARGET-IP>
```

Identify NFS Services

```
nmap -sV -p 111,2049 <TARGET-IP>
```

Enumerate NFS Exports in an Authorized Environment

```
showmount -e <TARGET-IP>
```

NFS-Related Enumeration

```
nmap --script nfs-ls,nfs-showmount -p 111,2049 <TARGET-IP>
```

Security Analysis

The probability of unauthorized access from at least one subnet is 66.4%, which represents a significant risk. After access is obtained, the probability of privilege escalation is 70%, resulting in an overall modeled compromise probability of 46.48%.

Restricting NFS access to a single trusted subnet reduces the modeled probability of complete compromise to 28%. This demonstrates that reducing the number of potential entry points is an effective security measure.

Recommended Mitigation

1. Restrict NFS exports to trusted hosts and subnets.
2. Apply least-privilege access.
3. Use appropriate NFS security mechanisms.
4. Block unnecessary NFS traffic using firewall rules.
5. Monitor NFS access.
6. Avoid exposing NFS beyond required network segments.

Final Conclusion

The probability of unauthorized NFS access is **66.4%**, while the probability of complete system compromise is **46.48%**. Restricting NFS access to a single trusted subnet reduces the modeled compromise probability to **28%**. Therefore, subnet restriction is an effective mitigation strategy when combined with strong authentication, authorization, firewall restrictions, and privilege controls.

QUESTION 5: SQL Injection and Database Data Exposure

5. An e-commerce platform maintains a database containing 50,000 user records, of which 30% are classified as sensitive. A successful SQL injection attack allows data extraction at a rate of 500 records per second. However, the application firewall detects and blocks the attack after 40 seconds.

Question:

Compute the total number of records that can be extracted before the attack is blocked. Determine the percentage of total data compromised, and estimate the number of sensitive records exposed. Based on your analysis, evaluate the severity of the breach and justify whether the existing detection mechanism is sufficient to protect critical data.

Problem Analysis

The e-commerce platform maintains a database containing 50,000 user records. A successful SQL injection attack can extract 500 records per second. The application firewall detects and blocks the attack after 40 seconds.

Given Data

- Total database records = 50,000
- Sensitive records = 30%
- Data extraction rate = 500 records/second
- Detection/blocking time = 40 seconds

Step 1: Total Number of Records Extracted

Records extracted:

Extraction Rate $\times$ Time

$$= 500 \times 40$$

$$= 20,000 \text{ records}$$

Therefore:

20,000 records can potentially be extracted before the attack is blocked.

Step 2: Percentage of Total Database Compromised

Percentage compromised:

$$(20,000 / 50,000) \times 100$$

$$= 40\%$$

Therefore:

40% of the database could potentially be exposed.

Step 3: Number of Sensitive Records Exposed

Total sensitive records:

$$50,000 \times 0.30$$

$$= 15,000 \text{ sensitive records}$$

Assuming that the extracted records have the same 30% sensitive-data distribution:

$$20,000 \times 0.30$$

$$= 6,000$$

Therefore:

Approximately 6,000 sensitive records could potentially be exposed.

Kali Linux Commands

Identify Web Services

```
nmap -sV -p 80,443 <TARGET-IP>
```

Identify Web Technologies

```
whatweb http://<TARGET-IP>
```

Perform Basic Web Server Security Assessment

```
nikto -h http://<TARGET-IP>
```

SQL Injection Testing

For an intentionally vulnerable application that you own or are explicitly authorized to test:

```
sqlmap -u "http://<TARGET-IP>/search.php?id=1" --dbs
```

Security Analysis

The attack can potentially extract up to 20,000 records, representing 40% of the complete database. If 30% of the extracted records are sensitive, approximately 6,000 sensitive records could be exposed.

This represents a **high-severity data breach** because a substantial portion of the database can potentially be extracted within the 40-second detection window.

The application firewall provides an important additional defense, but it is not sufficient as the primary protection against SQL injection. The vulnerability should primarily be prevented

through secure application development and database security controls.

Recommended Mitigation

1. Use parameterized queries and prepared statements.
2. Validate and sanitize user input.
3. Apply least privilege to database accounts.
4. Follow secure coding practices.
5. Conduct regular vulnerability assessments.
6. Configure WAF rules for SQL injection detection.
7. Monitor database access and abnormal query patterns.
8. Encrypt sensitive information where appropriate.

Final Conclusion

The SQL injection attack can potentially extract **20,000 records**, representing **40% of the database**, including approximately **6,000 sensitive records**.

Therefore, the breach should be classified as **high severity**. The existing firewall detection mechanism is useful but is **not sufficient by itself**. SQL injection should primarily be prevented through secure application development, parameterized queries, proper database access controls, and continuous security monitoring.

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context	
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts	
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution	
Use of Tools	15%	Effective use of modern tools, technologies, and real	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools	

		data				
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis	
Professionalism	5%	Highly professional, well documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation	